

Audit de sécurité - Application de réservation Ancrelieu (version Python / FastAPI)

Contexte de l'audit

Ancrelieu nous a confié un audit de sécurité de l'application de réservation, dans le cadre du renouvellement de contrat avec l'un de ses clients. Cet audit porte sur la version Python (FastAPI) de l'application, telle qu'elle est déployée actuellement en production.

L'audit a porté sur le système de comptes utilisateurs, la gestion des mots de passe, les mécanismes d'authentification et les contrôles d'accès aux données de réservation. Il ne couvre pas le déploiement ni la maintenance de l'application, qui font l'objet d'un chantier distinct.

Ce document liste les vulnérabilités constatées, par ordre de criticité décroissante, avec pour chacune une description en langage métier, le mécanisme technique en cause dans le code FastAPI, et la protection attendue.

Synthèse des constats

Quatre vulnérabilités ont été identifiées. Les trois premières sont critiques : elles exposent directement les données personnelles et financières des clients d'Ancrelieu. La quatrième est à traiter mais présente un risque plus limité.

Vulnérabilité · Criticité · Composant concerné

Mots de passe stockés en clair · Critique · services/user_service.py / table users

Absence d'authentification sur les endpoints sensibles · Critique · routers/reservations.py, routers/users.py

Absence de contrôle d'autorisation entre utilisateurs (IDOR) · Critique · routers/reservations.py

Absence de restriction sur les tentatives de connexion · Modérée · routers/auth.py

Vulnérabilité 1 : mots de passe stockés en clair

En langage métier : si notre base de données était consultée par une personne non autorisée, que ce soit un employé indélicat ou un attaquant externe, elle lirait directement le mot de passe de chaque client. Beaucoup de clients réutilisent le même mot de passe sur plusieurs services, ce qui étend le risque bien au-delà d'Ancrelieu.

Constat technique : la fonction `create_user` du module `services/user_service.py` enregistre le mot de passe reçu du formulaire d'inscription directement dans le champ `password` du modèle `User`, sans transformation. Aucune bibliothèque de hachage n'est importée dans le projet, et aucune vérification de hachage n'intervient à la connexion : la comparaison se fait par égalité directe de chaînes de caractères.

Protection attendue : les mots de passe doivent être hachés avant écriture en base, avec une bibliothèque de hachage éprouvée telle que `bcrypt` ou `passlib`, et un coût de calcul paramétrable. Le mot de passe en clair ne doit transiter qu'au moment de la connexion, jamais être conservé ni journalisé.

Vulnérabilité 2 : absence d'authentification sur les endpoints sensibles

En langage métier : n'importe qui, sans se connecter, peut aujourd'hui consulter la liste des réservations, créer une réservation au nom d'un tiers ou modifier une réservation existante en appelant directement l'adresse de l'API. Il suffit de connaître l'URL, ce qui est trivial à obtenir en inspectant le trafic du site.

Constat technique : les routes définies dans `routers/reservations.py` et `routers/users.py` ne déclarent aucune dépendance FastAPI de type `Depends(get_current_user)` ou équivalent. Aucun mécanisme de vérification de jeton n'est appelé avant l'exécution des fonctions de route : un client peut appeler `GET /api/reservations` ou `POST /api/reservations` sans fournir le moindre en-tête d'authentification.

Protection attendue : chaque endpoint qui manipule des données de réservation ou de compte doit exiger une authentification préalable, mise en œuvre via une dépendance FastAPI vérifiant un jeton (JWT ou session, selon ce que l'équipe retient) avant d'exécuter la logique de la route. Les seuls endpoints publics doivent rester l'inscription et la connexion.

Vulnérabilité 3 : absence de contrôle d'autorisation entre utilisateurs (IDOR)

En langage métier : même une fois connecté avec son propre compte, un client peut aujourd'hui consulter ou modifier la réservation d'un autre client, simplement en changeant un identifiant dans l'adresse consultée. C'est le point que le client nous a explicitement signalé comme inacceptable avant renouvellement.

Constat technique : la fonction `get_reservation` du routeur `routers/reservations.py` récupère la réservation correspondant à l'identifiant fourni dans l'URL et la retourne, sans comparer le champ `user_id` de la réservation à l'identifiant de l'utilisateur authentifié. Il s'agit d'une vulnérabilité de type IDOR (référence directe à un objet non protégée) : l'application fait confiance à l'identifiant fourni par le client sans le confronter au propriétaire réel de la ressource.

Protection attendue : chaque accès à une réservation doit être conditionné à la comparaison entre l'identifiant de l'utilisateur authentifié (extrait du jeton) et le propriétaire de la ressource demandée, avant tout renvoi de données. Ce contrôle doit être testé explicitement, avec une tentative d'accès à la réservation d'un autre utilisateur qui doit être refusée.

Vulnérabilité 4 : absence de restriction sur les tentatives de connexion

En langage métier : rien n'empêche aujourd'hui un script automatisé d'essayer des milliers de mots de passe à la suite sur le même compte, jusqu'à en trouver un qui fonctionne.

Constat technique : la fonction `login` du routeur `routers/auth.py` ne limite pas le nombre de tentatives par compte ou par adresse d'origine. Aucun compteur d'échecs ni verrouillage temporaire n'est en place, et aucune bibliothèque de limitation de débit (rate limiting) n'est utilisée sur cette route.

Protection attendue : ce point est à traiter si le temps le permet, mais il n'est pas bloquant pour le renouvellement du contrat. Il peut être écarté de ce chantier à condition que ce choix soit justifié et documenté.

Ce qui n'entre pas dans le périmètre de cet audit

Cet audit ne couvre ni le chiffrement des données au repos au niveau de la base de données, ni la

configuration réseau, ni les aspects de déploiement ou de journalisation applicative. Ces points seront traités dans un chantier ultérieur, distinct de la mise en conformité demandée par le client.